

CURSO RSI - CIBERSEGURIDAD

APLICADA CON IA

ACTIVIDAD: ARQUITECTURA DISTRIBUIDA SEGURA, STEP-UP MFA, SBOM, GESTIÓN DE VULNERABILIDADES BASADA EN RIESGOS Y ACCESO PRIVILEGIADO DIRECTO A BD

Modalidad: Trabajo práctico asistido con IA (opencode, Claude, ChatGPT, Gemini)

Base normativa / marco de referencia: Marco de Ciberseguridad AGESIC / BCU (SF.SEG.08), Ley N° 18.331 de Protección de Datos Personales (LPDP), OWASP Top 10 y NIST SP 800-218 (SSDF).

1. Contexto

En tu rol como Responsable de Seguridad de la Información (RSI), debes asegurar la interoperabilidad entre dos plataformas independientes: un **Frontend/Gateway** y un **Core de Datos Financieros**. La arquitectura debe mitigar riesgos en la cadena de suministro de software mediante un **Software Bill of Materials (SBOM)**, implementar autenticación escalonada (**Step-up MFA**) en endpoints críticos mediante aplicaciones móviles de autenticación, garantizar **inmutabilidad en la auditoría de accesos a bases de datos** y bloquear la **fuga de información (DLP)**, clasificando hallazgos bajo taxonomías formales (CWE/CVE) con un enfoque basado en riesgos.

2. Marco Teórico

- **¿Qué es TOTP (Time-based One-Time Password)?**: Estándar abierto (RFC 6238) que genera códigos numéricos temporales (generalmente de 6 dígitos) válidos durante ventanas cortas de tiempo (habitualmente 30 segundos). Se calcula mediante una función criptográfica HMAC ($HMAC-SHA1$) que combina una clave secreta compartida (*seed* base32) y la marca de tiempo actual ($T = \lfloor \text{UnixTime}/30 \rfloor$).
- **Integración con Apps Autenticadoras (Google Authenticator / Microsoft Authenticator / FreeOTP)**:
 - La aplicación servidora genera una clave secreta única para el usuario (`pyotp.random_base32()`).
 - Para enrolar el dispositivo, el servidor construye un URI bajo el estándar `otpauth://totp/Banco:usuario@dominio?secret=SECRETO&issuer=Banco` y lo proyecta como un **código QR** o cadena de texto.

- El usuario escanea el código en la app de su teléfono móvil. A partir de allí, el dispositivo móvil genera códigos sincronizados por tiempo sin requerir conexión a internet ni SMS.
- **Biometría vs. Código TOTP**: La biometría (huella dactilar/Face ID) en smartphones actúa como un mecanismo de **desbloqueo local** del almacén de claves del dispositivo (autenticación al dispositivo), mientras que el TOTP es el **factor de posesión** transmitido y validado contra el servidor backend.
- **Step-up MFA en Endpoints Críticos**: La sesión autenticada básica no es suficiente para acciones de alto impacto. El endpoint valida en tiempo de ejecución un token TOTP fresco (X-MFA-Code) antes de autorizar transacciones sensibles (como transferencias o modificaciones de privilegios).
- **Seguridad en la Cadena de Suministro (SBOM)**: Un *Software Bill of Materials* (en estándar **CycloneDX** o **SPDX**) inventaría dependencias directas y transitivas para detectar componentes desactualizados o vulnerables antes del despliegue.
- **Taxonomía de Vulnerabilidades (CWE vs. CVE vs. CVSS)**:
 - **CWE (Common Weakness Enumeration)**: El tipo de defecto de arquitectura o debilidad en el código fuente (ej. *CWE-306: Autenticación ausente para función crítica*).
 - **CVE (Common Vulnerabilities and Exposures)**: La instancia específica y pública del fallo en una librería/software concreto (ej. *CVE-2023-XXXXX*).
 - **CVSS (Common Vulnerability Scoring System)**: Escala numérica (0 a 10) que mide la severidad técnica intrínseca del fallo.
- **Gestión de Vulnerabilidades Basada en Riesgo (RBVM)**: Enfoque que prioriza la remediación considerando el contexto operativo real:

$$\text{Riesgo} = \text{Impacto al Negocio} \times \text{Probabilidad de Explotar}$$

- **RBAC y Log Inmutable**: Segregación estricta de privilegios y encadenamiento criptográfico:

$$\text{Hash}_{\text{actual}} = \text{SHA256}(\text{Timestamp})$$

3. Objetivos de Aprendizaje

- Desplegar dos sistemas comunicados vía API REST, uno desarrollado en **Python** y el otro en lenguaje a elección (o Python).
- Implementar enrolamiento y validación de **MFA TOTP** compatible con Google Authenticator en el login y en **Step-up MFA** en endpoints críticos.
- Generar un **SBOM en formato CycloneDX** utilizando herramientas libres (cyclonedx-py o syft).

- Construir una pista de auditoría con **logs inmutables encadenados** y un middleware **DLP** de inspección de datos salientes.
- Documentar vulnerabilidades asociando identificadores **CWE/CVE** bajo una matriz de riesgos formal.
- Diseñar e implementar controles de seguridad, monitoreo y **Bastion Host / PAM** para escenarios de acceso directo privilegiado a bases de datos.

4. Herramientas del Día

- **Python 3.10+** (Entornos virtuales venv).
- **Generador de SBOM:** cyclonedx-py (pip install cyclonedx-bom) o binario syft.
- **Librerías Python:** flask, pyotp, qrcode, sqlite3, requests, cryptography.
- **Dispositivo Móvil / Emulador:** Google Authenticator, Microsoft Authenticator o FreeOTP.
- **Asistente IA:** CLI (opencode) o interfaz web.

5. Desarrollo Paso a Paso

Paso 1: Enrolamiento MFA y Despliegue del Sistema A (Front / API Gateway)

- Desarrollar en **Python Flask** (puerto 5000) una interfaz con formulario de login.
- **Enrolamiento TOTP:** Al registrarse el usuario, generar un secreto base32 con pyotp y mostrar en pantalla la clave (o renderizar el código QR con la librería qrcode).
- El estudiante debe escanear o ingresar la clave secreta en su aplicación de autenticación móvil (Google Authenticator, Microsoft Authenticator, etc.).
- Al loguearse, el sistema debe solicitar contraseña y validar el código numérico dinámico de 6 dígitos antes de expedir la sesión.

Paso 2: Despliegue del Sistema B (Core API Backend / BD)

- Desarrollar el servicio backend (puerto 5001) en el stack de preferencia (Python, Node.js, etc.):
 - GET /api/v1/resumen: Requiere cabecera de autenticación entre sistemas (X-API-KEY o Bearer Token).
 - POST /api/v1/transferencia: Endpoint crítico. Exige la API-Key y adicionalmente el header X-MFA-Code (Step-up MFA). Si el código TOTP es inválido o no está presente, rechazar con HTTP 401.
 - GET /api/v1/clientes: Expone datos personales protegidos bajo reglas DLP.

Paso 3: RBAC y Log Inmutable en Base de Datos

- Diseñar la base de datos con tablas clientes, cuentas y auditoria_accesos.
- Establecer perfiles de conexión: rol aplicativo (solo SELECT/INSERT en tablas de negocio) y rol auditor (solo lectura de pistas).
- Implementar el mecanismo de encadenamiento criptográfico de log: cada query ejecutada registra en auditoria_accesos:

$$\text{Hash}_{\text{actual}} = \text{SHA256}(\text{Timestamp})$$

Paso 4: Middleware DLP y Prevención de Exfiltración

- Implementar un interceptor/middleware en el Sistema B que inspeccione los payloads salientes de /api/v1/clientes.
- Si la respuesta contiene más de 5 registros de clientes sin paginación o expone documentos de identidad / tarjetas en texto claro, bloquear la respuesta con HTTP 403 y registrar un evento crítico de seguridad.

Paso 5: Generación de SBOM

- Generar el inventario de software del proyecto en formato estándar CycloneDX ejecutando en terminal:
`cyclonedx-py environment -o sbom-sistema.json`
 # O alternativamente con syft:
`# syft dir:. -o cyclonedx-json > sbom-sistema.json`
- Inspeccionar el archivo JSON resultante para verificar dependencias directas, transitivas y licencias.

Paso 6: Gestión de Vulnerabilidades Basada en Riesgo

- Utilizando la IA, analizar el SBOM y la arquitectura creada.
- Identificar 2 debilidades comunes (**CWE**) y asociar posibles vulnerabilidades (**CVE**) presentes en dependencias o flujos.
- Mapear los hallazgos en la matriz de riesgos del informe clasificando por probabilidad, impacto en el negocio y contexto de exposición.

6. Caso de Uso Aplicado: Acceso Directo de un Alto Directivo a la Base de Datos

Escenario:

El Directorio o un Gerente General solicita acceso directo e irrestricto a la base de datos de producción mediante un cliente SQL (DBeaver, pgAdmin) para ejecutar consultas analíticas inmediatas sin pasar por la aplicación web.

Riesgos para el RSI:

- **Violación del principio de mínimo privilegio y segregación de funciones:** El rol directivo no debe tener permisos de modificación/borrado (UPDATE, DELETE, DROP).
- **Fuga masiva de información confidencial / PII:** Extracción masiva sin controles de paginación ni DLP aplicativo.
- **Falta de trazabilidad y no repudio:** Las conexiones directas por credenciales

compartidas impiden saber quién ejecutó qué consulta.

- **Incumplimiento normativo:** Violación de la Ley 18.331 y normativas del BCU / AGESIC sobre control y registro de accesos a datos sensibles.

Solución Arquitectónica Exigida (Bastion + PAM + Auditoría + MFA):

[Directivo / Cliente SQL]

|

▼ (Requiere VPN / Zero Trust Network Access)

| Bastion Host / PAM Gateway (Privileged Access Mgt.) |

| - Autenticación con MFA obligatorio (TOTP / Hardware) |

| - Grabación de sesión y registro de comandos SQL |

| - Aprobación Just-in-Time (JIT) por ventana de tiempo |

|

▼ (Conexión cifrada TLS con usuario restringido)

| Base de Datos de Producción |

| - Usuario: `directorio\_ro` (Solo SELECT en vistas) |

| - Data Masking: Enmascaramiento de PII (CI, saldos) |

| - Tabla de Auditoría Inmutable (Hash Chaining) |

Cómo implementarlo paso a paso:

- **1. Acceso a través de Bastion / PAM:** Prohibir la apertura de puertos de base de datos a redes abiertas. La conexión debe transitar obligatoriamente por un servidor Bastion / Proxy de base de datos (ej. Teleport, StrongDM o túnel SSH con MFA) que autentica al directivo mediante credenciales nominativas y segundo factor (TOTP).
- **2. Principio de Acceso Just-in-Time (JIT):** El acceso no es permanente; se habilita una ventana temporal (ej. 2 horas) previa justificación de la necesidad de negocio.
- **3. Rol Restringido y Vistas Seguras (RBAC):** Crear un usuario exclusivo en la base de datos con permisos estrictamente de solo lectura (SELECT) limitado únicamente a vistas sanitizadas donde los datos sensibles (números de tarjeta, documentos) estén parcialmente enmascarados (*Dynamic Data Masking*).
- **4. Registro de Auditoría de Queries:** El proxy o motor de base de datos registra cada instrucción SQL ejecutada, asociándola a la identidad real del directivo y persistiendo el registro en la tabla de auditoría con hash encadenado.

7. Prompts Sugeridos para la IA (opencode)

- *"Genera un script en Python Flask que cree un secreto TOTP con pyotp, lo exponga como URL otpauth para Google Authenticator y verifique el código de 6 dígitos ingresado por el usuario."*
- *"Escribe un endpoint en Flask /api/v1/transferencia que implemente Step-up MFA validando el header X-MFA-Code antes de ejecutar la transacción."*
- *"¿Cómo genero un SBOM en formato CycloneDX JSON para un entorno virtual de Python usando cyclonedx-py o syft?"*
- *"Explica con ejemplos prácticos la diferencia entre CWE, CVE y CVSS, y cómo se aplican en una matriz de Gestión de Vulnerabilidades Basada en Riesgo (RBVM)."*
- *"Diseña una arquitectura de Bastion Host con Privileged Access Management (PAM) y Data Masking para permitir acceso de solo lectura y con auditoría a un directivo sobre una base de datos de producción."*

8. Documentación del RSI (Bitácora)

Registrar en bitacora.md de la actividad:

- Diagrama de flujo de autenticación (Login MFA y Step-up MFA).
- Comprobación de integridad de la cadena criptográfica de auditoría.
- Archivo SBOM generado (sbom-sistema.json).
- Análisis y resolución del caso de uso de acceso directivo a base de datos.

9. Evidencias a Capturar y Guardar

Guardar en la carpeta evidencias/ bajo el estándar EVI-YYYY-MM-DD-NN-descripcion.ext:

- EVI-2026-01-mfa-enroll.png: Captura de pantalla del secreto/QR enrolado en la aplicación de autenticación móvil.
- EVI-2026-02-stepup-block-ok.png: Petición a /transferencia rechazada sin MFA (401) y aprobada al enviar X-MFA-Code válido (200).
- EVI-2026-03-hashchain-audit.png: Tabla SQL con encadenamiento de registros (prev_hash y current_hash).
- EVI-2026-04-dlp-blocked.png: Bloqueo del middleware DLP ante intento de extracción masiva.
- EVI-2026-05-sbom-cyclonedx.png: Fragmento estructurado del archivo CycloneDX generado.
- EVI-2026-06-caso-directivo-arquitectura.png: Diagrama/flujo del esquema de acceso seguro con Bastion y enmascaramiento para el caso del directivo.

10. Entregable de la Clase

Código de ambos sistemas + base de datos con pistas de auditoría + SBOM (sbom-sistema.json) + carpeta evidencias/ + archivo informe.md.

Anexo A - Plantilla de Informe Ejecutivo para Órgano Regulador / BCU

Encabezado del informe

- **Institución:** Banco Ficticio del Uruguay
- **Responsable de Seguridad de la Información (RSI):** [Nombre y cargo]
- **Destinatario:** Banco Central del Uruguay - Superintendencia de Instituciones Financieras
- **Asunto:** Evaluación de Controles de Acceso Escalonado (Step-up MFA), Trazabilidad Inmutable, SBOM, DLP y Control de Accesos Privilegiados a BD
- **Fecha:** [dd/mm/aaaa] | **Versión:** 1.0 | **Clasificación:** Confidencial

1. Resumen Ejecutivo

[Síntesis ejecutiva sobre la verificación técnica de interoperabilidad segura entre microservicios, implementación de autenticación fuerte con TOTP, inventario de dependencias bajo SBOM, contención de fuga de información y controles de acceso privilegiado PAM/Bastion conforme a la norma SF.SEG.08].

2. Marco Normativo y Estándares Aplicables

- Norma de Ciberseguridad del BCU (SF.SEG.08) y Marco de Ciberseguridad de AGESIC.
- Ley N° 18.331 de Protección de Datos Personales y Acción de Habeas Data.
- Estándares: OWASP CycloneDX (SBOM), RFC 6238 (TOTP), taxonomías CWE y CVE.

3. Matriz de Gestión de Vulnerabilidades Basada en Riesgos (RBVM)

ID	Activo / Compon ente	CWE / CVE	CVSS Base	Exposici ón / Contexto	Nivel de Riesgo Real	Plan de Tratamie nto
V-01	Endpoint /transfere ncia	CWE-306 / N/A	8.8 (Alto)	Endpoint transacci onal interno	Crítico	Mitigado con Step-up MFA (X-MFA- Code)
V-02	Base de Datos Core	CWE-284 / N/A	7.5 (Alto)	Acceso de administr ación / queries	Alto	Mitigado con RBAC, PAM y Hash Chaining
V-03	Librería HTTP en SBOM	CVE-202 3-XXXX	5.3 (Medio)	Depende ncia transitiva	Bajo (Aceptad o)	Programa do para actualiza

				sin vector activo		ción de rutina
V-04	Endpoint /clientes	CWE-200 / N/A	7.5 (Alto)	Potencial exfiltración de PII	Alto	Mitigado mediante Middlewa re DLP

4. Dictamen Técnico sobre Acceso Directo de Directivos a Bases de Datos

[Descripción del dictamen del RSI estableciendo la obligatoriedad de conexión mediante Bastion PAM con MFA, asignación de rol de solo lectura sobre vistas con Data Masking y auditoría inmutable de sentencias ejecutadas].

5. Conclusiones y Firmas

- Firma del RSI:
- Fecha:

Anexo B - Rúbrica de Evaluación

Criterio	Logrado (3)	En Desarrollo (2)	No Logrado (1)
Arquitectura & Step-up MFA	Doble sistema funcional; enrolamiento TOTP con app móvil y validación X-MFA-Code en endpoints críticos.	MFA operativo solo en el login inicial o sin compatibilidad con app móvil estándar.	Falla la comunicación entre sistemas o carece de validación MFA.
Auditoría Inmutable & DLP	Log encadenado por SHA-256 verificado y middleware que bloquea exfiltración de PII.	Registra logs o DLP pero sin verificación criptográfica de integridad ni bloqueo efectivo.	Sin pistas de auditoría ni inspección de tráfico saliente.
SBOM & Gestión de Vulnerabilidades	Genera SBOM en formato CycloneDX y clasifica debilidades (CWE/CVE) bajo	Genera SBOM pero no clasifica adecuadamente CWE/CVE ni prioriza según	No genera SBOM ni documentación técnica de vulnerabilidades.

	matriz de riesgos.	riesgo de negocio.	
Resolución Caso Directivo (PAM)	Diseña e implementa la solución con Bastion Host, MFA, rol de solo lectura, data masking y auditoría.	Propone usuario de base de datos sin contemplar Bastion, MFA o enmascaramiento.	Aprueba acceso directo sin controles de seguridad ni trazabilidad.
Evidencias & Reporte	Cumple con nomenclatura EVI-..., bitácora completa y reporte ejecutivo formal.	Faltan evidencias técnicas o informe incompleto.	No entrega bitácora, evidencias ni reporte técnico.